

Cahier des Charges

Application de Centralisation des Logs & Alertes – Freemopay

1. Objectifs du Projet

- Centraliser les logs applicatifs et système de toutes les applications internes (multi-technologies).
 - Permettre une collecte performante sans impacter les performances des applications sources.
 - Fournir une interface de supervision, d'analyse, de recherche et d'alerte sur les événements critiques.
 - Permettre le suivi des activités utilisateurs pour la traçabilité réglementaire.
-

2. Périmètre Fonctionnel

2.1. Collecte des Logs

-  **Collecte via API** : chaque application peut envoyer ses logs via une API REST sécurisée (avec clés d'authentification/jetons JWT).
-  **Collecte via agent serveur** :
 - Agent léger installé sur chaque serveur applicatif.
 - Capable de lire en temps réel ou par intervalle les fichiers de logs (`tail -f` ou lecture de fichiers `.log`).
 - Compatible Linux (Debian, Ubuntu, CentOS) & Windows Server si nécessaire.
 - Support de formats : JSON, plain text, syslog, etc.
 - Signature de logs (hash SHA-256) pour garantir intégrité si exigé.
-  **Collecte à distance via journaux système** :
 - Support de Syslog, journald, Windows Event Viewer.

2.2. Distribution des Logs

- Acheminement vers une **base centrale** (ElasticSearch ou ClickHouse recommandé).
- Normalisation des logs (horodatage, niveau, source, application, type d'environnement...).
- Routage intelligent par niveau (info, warning, error, critical) et par application.

2.3. Alerting & Notifications

- Système de règles personnalisables (ex. : "si erreur critique sur app X > notifier en moins de 1 min").
- Envoi des alertes par :
 - Slack / Microsoft Teams
 - Email
 - Webhook custom
 - Télégram
- Dashboard de configuration des règles.

2.4. Interface Utilisateur

- Tableau de bord global avec filtres (app, environnement, date, type de log).
- Vue temporelle des événements.
- Recherche full-text avec autocomplétion.
- Visualisation de logs en temps réel.
- Marquage de logs importants pour audit.
- Système de permissions : rôle "admin", "auditeur", "viewer".

2.5. Suivi d'Activité Utilisateur

- Capture des actions utilisateurs côté front/backend (clics, requêtes critiques, exportations de données...).
- Corrélation des logs avec un identifiant utilisateur anonymisé ou token sécurisé.

- Journal d'audit avec possibilité d'export CSV/PDF.
- Fonction "session replay" simple possible (moyennant frontend JS SDK en option).

2.6. Sécurité

- Authentification forte (JWT, SSO, 2FA possible).
 - Chiffrement en transit (HTTPS) et au repos (AES-256).
 - Permissions fines sur l'accès aux logs.
 - Option d'auto-destruction des logs sensibles (conformité RGPD, PCI-DSS).
 - Détection d'injections ou logs malformés.
-

3. Périmètre Technique

3.1. Technologies Compatibles

- Node.js, NestJS, Java, Python, PHP, Go, Ruby, etc.
- Support Docker / Kubernetes (sidecar logging).
- Intégration CI/CD : Jenkins, GitHub Actions, GitLab, etc.

3.2. Stockage & Architecture

- Stockage suggéré : Elasticsearch, OpenSearch, ClickHouse, ou Loki.
 - Backend : Node.js/NestJS recommandé pour cohérence avec l'écosystème.
 - Interface : React (admin UI), tailwind/MUI, ou Angular si existant.
 - Agent : Go ou Rust pour performance.
-

4. Fonctionnalités Avancées

-  **Replay de logs** (pour rejouer une séquence).

- 🕒 **SLA Tracking** : durée entre alerte et prise en charge.
 - 📊 **Statistiques dynamiques** : volume de logs/app, erreurs/jour, etc.
 - 🧠 **Moteur de corrélation** : regroupe des logs liés à un incident.
 - 📦 **Export Logs** : pour archivage ou transfert légal.
 - ⌚ **Rétention configurable** : ex. 90 jours pour info, 1 an pour erreur, illimité pour audit.
-

5. Livrables attendus

- Agents (binaire ou Docker) de collecte prêts à déployer.
 - Backend API + DB centralisée des logs.
 - Dashboard d'administration et consultation.
 - Documentation technique (installation, intégration, API).
 - Guide RGPD/compliance (si logs contiennent données perso).
 - Scripts de déploiement Docker/Kubernetes.
-

6. Exigences Non-Fonctionnelles

- 🛠 Haute disponibilité.
- 📈 Scalabilité horizontale.
- 🚀 Temps de réponse API < 100ms.
- 🔒 Conforme RGPD, ISO 27001, PCI-DSS (si paiement).
- 📦 Support de backup et archivage.